

Information Security Policy

Field	Value
Document ID	SEC-POL-001
Version	1.0
Effective	June 1, 2026
Owner	Eric Franco, CEO
Next Review	June 1, 2027
Status	Active

1. Purpose and Scope

This Information Security Policy establishes the security standards, controls, and responsibilities for Naviio, Inc. ("Naviio," "we," "the Company"). It applies to:

- All employees, contractors, and third-party vendors who access Naviio systems
- All systems, applications, and infrastructure operated by Naviio
- All customer data processed, stored, or transmitted by Naviio

Naviio provides AI-powered financial intelligence to small and mid-market businesses ("customers"). Our platform ingests sensitive business financial data — including bank transactions, accounting records, and revenue data — making strong information security non-negotiable.

2. Data Classification

All data handled by Naviio is classified into one of four tiers:

Tier	Label	Description	Examples
1	Critical	Data whose exposure would cause severe harm to customers or the company	Bank account numbers, OAuth access tokens, API keys, passwords
2	Confidential	Sensitive business data with restricted access	Transaction records, balances, P&L data, customer PII
3	Internal	Non-public operational data	System logs, internal metrics, configuration files
4	Public	Information approved for external distribution	Marketing content, public documentation

Handling requirements by tier:

- **Critical:** Encrypted at rest (AES-256) and in transit (TLS 1.2+). Access logged. Never stored in plaintext. Rotated on schedule or immediately upon suspected compromise.

- **Confidential:** Encrypted at rest and in transit. Access restricted to authorized personnel with documented business need. Logged and auditable.
 - **Internal:** Protected from external access. Accessible to employees on a need-to-know basis.
 - **Public:** No access controls required; standard publishing workflow applies.
-

3. Encryption Standards

3.1 Data at Rest

- All customer data stored in AWS RDS PostgreSQL is encrypted using **AES-256**.
- Database encryption is enforced at the storage layer via AWS RDS encryption (AWS KMS-managed keys).
- S3 buckets (report storage) use **SSE-S3** (AES-256) with server-side encryption enabled by default.
- OAuth access tokens and API keys stored in the database are additionally encrypted at the application layer before persistence.
- Secrets (database credentials, API keys) are stored exclusively in **AWS Secrets Manager** and never in source code, environment files checked into version control, or unencrypted configuration stores.

3.2 Data in Transit

- All data transmitted between customers and Naviio is encrypted using **TLS 1.2 or higher**. TLS 1.0 and 1.1 are explicitly disabled.
- HTTPS is enforced via HTTP Strict Transport Security (HSTS) headers with a minimum max-age of 1 year.
- Internal service-to-service communication (e.g., application server to database) occurs over encrypted connections within the AWS VPC.
- TLS certificates are provisioned through AWS Certificate Manager (ACM) and auto-renewed.

3.3 Key Management

- AWS KMS is the authoritative key store for database and S3 encryption keys.
 - Application-layer encryption keys are rotated annually or upon suspected compromise.
 - No employee has direct access to production encryption keys. Key usage is logged in AWS CloudTrail.
-

4. Access Control

4.1 Principles

Naviio enforces the principle of **least privilege**: access is granted only to the minimum resources required to perform a job function, and access is revoked immediately upon role change or departure.

4.2 Employee Access

- All production system access requires individual named accounts. Shared credentials are prohibited.
- Access to production databases, AWS infrastructure, and customer data requires documented approval from the CEO.
- Production access is logged in AWS CloudTrail and reviewed quarterly.
- Departed employees and contractors have all access revoked within **2 hours** of termination.

4.3 Authentication Requirements

- **Multi-Factor Authentication (MFA) is mandatory** for all accounts with access to:

- AWS Management Console
 - GitHub repositories
 - Vercel deployment environment
 - Any system storing Tier 1 or Tier 2 data
- Acceptable MFA factors: TOTP authenticator app (e.g., 1Password, Authy), hardware security key (FIDO2). SMS-based MFA is not permitted for production system access.
 - Session tokens expire after 8 hours of inactivity for internal tools.

4.4 Password Policy

- Minimum length: **16 characters**
- Must include: uppercase, lowercase, digit, and special character
- Prohibited: reuse of last 12 passwords, dictionary words, or any variant of "Naviio," the company name, or personal information
- Passwords are stored as **bcrypt hashes** (cost factor ≥ 12); plaintext passwords are never stored or logged
- Mandatory rotation: upon suspected compromise; encouraged annually for high-privilege accounts

4.5 Third-Party API Keys

- All third-party API keys (Plaid, Stripe, QuickBooks, etc.) are stored in AWS Secrets Manager
 - Keys are scoped to the minimum permissions required (e.g., Plaid read-only, Stripe read-only where applicable)
 - Keys are rotated annually or immediately upon suspected compromise
-

5. Network Security

- Production infrastructure is deployed within a **private AWS VPC**. Database and cache instances are in private subnets with no public internet exposure.
 - Inbound traffic to the application server is restricted to ports 443 (HTTPS) via an Application Load Balancer (ALB).
 - AWS WAF is deployed in front of the ALB to detect and block common web attack patterns (OWASP Top 10), SQL injection, and rate-limit abuse.
 - SSH access to EC2 instances is restricted to the engineering team via IP allowlist and requires SSH key authentication. Password-based SSH is disabled.
 - Security group rules are reviewed quarterly; unused rules are removed.
-

6. Vulnerability Management

- Dependencies are scanned via `npm audit` on every CI build. Critical vulnerabilities block deployment.
 - **GitHub Dependabot** monitors all dependencies for known CVEs and opens automated pull requests.
 - OS-level patches are applied to production EC2 instances within **7 days** of a critical CVE disclosure, **30 days** for high severity.
 - A penetration test is conducted annually by a qualified third-party firm. Findings are remediated per severity: Critical ≤ 7 days, High ≤ 30 days, Medium ≤ 90 days.
-

7. Vendor and Third-Party Management

Naviio relies on the following critical vendors:

Vendor	Purpose	Data Shared
Plaid	Bank data aggregation	OAuth tokens; transaction/balance data fetched in real time
Stripe	Revenue/subscription data	Stripe account OAuth token; read-only access to revenue metrics
Intuit (QuickBooks)	Accounting data	OAuth tokens; accounting records fetched via API
AWS	Cloud infrastructure	Hosts all customer data
Vercel	Application hosting/CDN	Hosts application code; no direct customer data access
Anthropic	AI analysis (Claude API)	Aggregated financial summaries sent for analysis; no raw PII

Vendor security requirements:

- All vendors must maintain SOC 2 Type II certification or equivalent, reviewed annually.
- Contracts include data processing agreements (DPAs) where applicable.
- Vendor API tokens are stored exclusively in AWS Secrets Manager.
- Data shared with Anthropic for AI analysis is limited to aggregate financial summaries. Raw transaction data, account numbers, and PII are never transmitted to AI providers.

8. Incident Response

A full Incident Response Plan is maintained in `docs/security/incident-response-plan.md`. Key points:

- Incidents are classified as Critical, High, Medium, or Low based on data exposure risk and operational impact.
- **Eric Franco (CEO/CTO)** is the Incident Response Lead and first point of escalation.
- Customers affected by a Tier 1 or Tier 2 data breach are notified within **72 hours** of confirmed discovery.
- Plaid is notified per the Plaid Developer Agreement within **24 hours** of any confirmed incident involving Plaid-connected data.
- A post-incident review ("blameless postmortem") is conducted within 5 business days of all Critical and High incidents.

9. Physical Security

- Naviio is a remote-first company. No on-premises servers exist; all production infrastructure is cloud-hosted on AWS.
- Employee workstations must use full-disk encryption (FileVault on macOS, BitLocker on Windows).
- Lost or stolen employee devices must be reported to the CEO within **1 hour**. Remote wipe is initiated for any device with access to production systems or customer data.
- Screen locks activate after **5 minutes** of inactivity on all devices with access to internal systems.

10. Security Awareness

- All new hires complete security awareness training within their first 30 days.
 - Annual refresher training is required for all employees covering: phishing, social engineering, password hygiene, and data handling.
 - Phishing simulation exercises are conducted at least twice per year.
 - Employees are encouraged to report suspicious activity via the security incident reporting process without fear of blame.
-

11. Policy Violations

Violations of this policy may result in disciplinary action up to and including termination, and may be reported to relevant regulatory authorities where required by law.

12. Review and Maintenance

This policy is reviewed annually (or following any significant security incident, regulatory change, or material change to Naviio's data processing activities) by the CEO. Exceptions to this policy require written approval from the CEO and are logged with a defined expiration date.
